

ISRM Lab 4: Residual Risk & Control Effectiveness

Course: Information Security & Risk Management (ISRM)

Lab Title: Quantitative Risk Assessment using the Control Strength Model

LAB OBJECTIVES

The final lab focuses on the quantification of security improvements and the mapping of threats to the STRIDE framework.

- Perform a complete **STRIDE Threat Analysis** for the application.
- Quantify **Inherent Risk** using Likelihood and Impact metrics.
- Evaluate **Control Strength** (C_s) for every remediation applied in previous labs.
- Calculate **Residual Risk** and produce a final Risk Register.
- Analyze the effectiveness of "Defense in Depth" in reducing total risk exposure.

BACKGROUND THEORY: THE RISK EQUATION

In this lab, we move away from purely financial metrics to a control-centric risk model. We define risk through the following mathematical relationships:

1. Inherent Risk (R_{inh})

The risk level present in the "Vulnerable Version" of the application before any security measures are applied.

$$\text{Inherent Risk} = \text{Likelihood} \times \text{Impact}$$

Scale (1–5): Both Likelihood and Impact are measured on a scale of 1 (Lowest) to 5 (Highest). The maximum Inherent Risk score is **25**.

2. Residual Risk (R_{res})

The risk remaining after security controls have been implemented in the "Fixed Version."

$$R_{res} = R_{inh} \times (1 - C_s)$$

where **Control Strength** (C_s) is a decimal value between 0.0 and 1.0 (representing 0% to 100% effectiveness).

PART A: STRIDE THREAT MAPPING

Students must categorize each vulnerability according to the STRIDE model to identify which security property is being violated.

ID	Vulnerability	STRIDE Category	Security Property Violated
V1	SQL Injection	Tampering, Info Disclosure	Integrity, Confidentiality
V2	Brute Force	Spoofing	Authentication
V3	Insecure File Upload	Tampering, Elevation of Privilege	Integrity, Authorization
V4	Path Traversal	Information Disclosure	Confidentiality
V5	CSRF	Tampering	Integrity
V6	Missing Access Control	Elevation of Privilege	Authorization
V7	Plain-text Passwords	Information Disclosure	Confidentiality
V8	Session Hijacking	Spoofing	Authentication
V9	Hardcoded Secrets	Information Disclosure	Confidentiality
V10	Verbose Errors	Information Disclosure	Confidentiality

PART B: INHERENT RISK ASSESSMENT (PRE-CONTROL)

This stage evaluates the "Vulnerable" state of the Student Management System. We assess how likely an attack is and how severe the impact would be on the student database and server integrity.

#	Risk Description	Likelihood	Impact	Inherent Risk	Severity
1	Data Breach via SQLi	5	5	25	Critical
2	Account Takeover (Brute Force)	5	4	20	High
3	Full Server Compromise (RCE)	3	5	15	High
4	Unauthorized Log Access	4	3	12	Medium
5	Admin Impersonation (Session)	3	4	12	Medium
6	Automated Record Creation (CSRF)	4	2	8	Low
7	Source Code Theft (Path Traversal)	3	4	12	Medium
8	Config Exposure (Hardcoded Creds)	2	5	10	Medium

PART C: CONTROL STRENGTH & RESIDUAL RISK CALCULATION

By applying the remediation logic from Labs 1, 2, and 3, we evaluate the **Control Strength** (C_s) and calculate the final **Residual Risk** (R_{res}).

#	Control Applied	Inherent Risk	Control Strength (C_s)	Residual Risk	% Reduction
1	Parameterized Queries	25	0.98 (98%)	0.50	98.0%
2	Account Lockout / Rate Limit	20	0.90 (90%)	2.00	90.0%
3	Extension Whitelist / secure_fn	15	0.95 (95%)	0.75	95.0%
4	Role-Based Access Control	12	0.92 (92%)	0.96	92.0%
5	Secure/HttpOnly/SameSite Flags	12	0.85 (85%)	1.80	85.0%
6	CSRF Token Validation	8	0.95 (95%)	0.40	95.0%
7	Absolute Path Verification	12	0.90 (90%)	1.20	90.0%
8	Environment Variables (os.get)	10	0.80 (80%)	2.00	80.0%

PART D: RESIDUAL RISK ANALYSIS

1. Average Control Effectiveness

The **Average Control Effectiveness** is calculated by finding the mean of all C_s values. For this project, the target is $> 90\%$.

$$\text{Avg. Effectiveness} = \frac{\sum C_s}{n}$$

2. Risk Acceptance Criteria

Risks that result in a **Residual Risk score of ≤ 2.0** are typically deemed "Acceptable" by the organization. Any risk scoring higher (e.g., Session Hijacking at 1.80 is acceptable, but Brute Force at 2.00 is on the threshold) requires continuous monitoring or additional layers of security (Defense in Depth).

3. Analyzing Residual Threats

Even with 100% code-level remediation, residual risk is never zero due to:

- **Configuration Drift:** Secure settings might be manually reverted by administrators.
- **Logic Flaws:** Parameters might be sanitized, but the business logic itself might still be flawed.
- **Zero-Day Vulnerabilities:** The security tools (Bandit/ZAP) may not have rules for brand-new attack vectors.

LAB REPORT REQUIREMENTS

Students must submit a structured report with the following data points:

1. **Qualitative Risk Matrix:** A 5x5 Likelihood vs. Impact heat map showing the position of the 8 core risks before and after controls.
2. **STRIDE Mapping Justification:** Choose 3 risks and explain in detail which security property (Authentication, Integrity, etc.) was prioritized during remediation.
3. **Calculation Proof:** Show the step-by-step arithmetic for the Residual Risk calculation of the "SQL Injection" and "Insecure File Upload" risks.
4. **Control Strength Evaluation:** A brief paragraph explaining why "Parameterized Queries" were assigned a higher strength (0.98) compared to "Environment Variables" (0.80).
5. **Final Risk Register:** A consolidated table showing the transition from Inherent to Residual risk for all assessed vulnerabilities.

CRITICAL THINKING QUESTIONS

1. Why is the formula for Residual Risk multiplicative rather than additive?
2. If a control has a strength of 0.50 (50%), and the Inherent Risk is 20, what is the Residual Risk? Is this generally acceptable for a "High" impact vulnerability?
3. How does the implementation of a CI/CD security gate (from Lab 2) improve the **Likelihood** score in the Inherent Risk equation?
4. Explain the difference between **Risk Mitigation** (applying controls) and **Risk Acceptance** (acknowledging residual risk).